

KRAMCOM CTF MACHINE WALKTHROUGH

Overview

KramCom is a telecom-themed Capture The Flag machine designed to simulate a realistic penetration testing scenario. Participants progress through multiple phases including reconnaissance, web enumeration, authentication bypass, database exploitation, system access, and privilege escalation.

The challenge contains seven flags distributed across different layers of the application and operating system.

Phase 1 – Reconnaissance

Objective

Identify the attack surface and discover hidden application components.

Activities Performed

- Network scanning to identify exposed services.
- Manual inspection of the web application.
- Discovery of hidden directories and files.
- Analysis of publicly accessible resources.

Findings

The web application exposes several directories that are not linked from the main website. Further enumeration reveals administrative functionality and backup-related resources that may contain sensitive information.

Outcome

The first flag is obtained through analysis of exposed information that should not normally be accessible to unauthenticated users.

Phase 2 – Authentication Analysis

Objective

Gain access to privileged functionality within the web application.

Activities Performed

- Identification of administrative login functionality.
- Evaluation of authentication controls.
- Testing for weak credential policies.

Findings

The application uses weak authentication practices that allow administrative access through predictable credentials.

Outcome

Successful authentication reveals sensitive subscriber-related information and the second flag.

Phase 3 – Database Exploitation

Objective

Investigate application inputs and identify database-related vulnerabilities.

Activities Performed

- Testing application parameters for improper input validation.
- Monitoring application responses for database errors.
- Attempting controlled database queries.

Findings

A backend search feature fails to properly sanitize user-supplied input, allowing database information to be extracted.

Outcome

Sensitive records are retrieved from the database, revealing the third flag.

Phase 4 – User-Level Access

Objective

Move beyond the web application and obtain operating-system-level access.

Activities Performed

- Review of information gathered during previous phases.
- Identification of credential reuse patterns.
- Testing remote access services.

Findings

Credentials discovered during web exploitation are reused elsewhere within the environment.

Outcome

A low-privilege user account is obtained, providing shell access to the target system and revealing the fourth flag.

Phase 5 – System Enumeration

Objective

Enumerate the Linux system to identify additional information and hidden artifacts.

Activities Performed

- Examination of user directories.
- Inspection of configuration files.
- Review of application-related logs.

Findings

Several telecom-related logs and configuration files contain sensitive operational information.

Outcome

Additional flags are discovered through analysis of system logs and configuration data.

Phase 6 – Lateral Movement

Objective

Access a higher-privileged user account.

Activities Performed

- Analysis of notes and operational artifacts.
- Identification of password reuse and weak credential management.
- Authentication testing against available user accounts.

Findings

Poor credential hygiene enables movement between accounts without exploiting additional vulnerabilities.

Outcome

Access is obtained to a more privileged user account, allowing deeper system enumeration.

Phase 7 – Privilege Escalation

Objective

Gain full administrative control of the system.

Activities Performed

- Enumeration of sudo permissions.
- Analysis of executable scripts available to privileged users.
- Review of file ownership and execution context.

Findings

A misconfigured administrative backup mechanism can be executed with elevated privileges.

Outcome

The vulnerability is leveraged to access sensitive root-owned resources and obtain the final flag.

Vulnerabilities Identified

The machine demonstrates several common security weaknesses:

Information Disclosure

Sensitive resources were exposed through publicly accessible locations.

Weak Authentication

Administrative access relied on predictable credentials.

SQL Injection

Application inputs were not properly sanitized before database queries.

Credential Reuse

The same credentials were used across multiple services.

Sensitive Data Exposure

Logs and configuration files contained valuable information that should have been restricted.

Improper Privilege Management

Administrative scripts could be executed with elevated permissions.

Attack Chain Summary

Reconnaissance



Hidden Resources Discovery



Admin Authentication



SQL Injection



User Access



System Enumeration



Lateral Movement



Privilege Escalation



Root Access

Lessons Learned

This machine demonstrates how multiple low-to-medium severity weaknesses can be chained together to achieve complete system compromise. While each individual vulnerability may appear minor, the combination of information disclosure, weak authentication, SQL injection, credential reuse, and privilege misconfiguration creates a realistic attack path that mirrors many real-world security incidents.